

PADRÕES DE VERIFICAÇÃO DE SEGURANÇA DE APLICAÇÕES**SUMÁRIO DA NORMA**

1	FINALIDADE,4
2	DEFINIÇÕES,4
3	REGRAS,4
3.1	DIRETRIZES GERAIS,4
3.2	CLASSIFICAÇÃO DO SISTEMA,5
3.3	TRILHA DE AUDITORIA NOS SISTEMAS,5
3.4	IDENTIFICAÇÃO,5
3.5	AUTENTICAÇÃO E AUTORIZAÇÃO,5
3.6	ARQUITETURA E DESENVOLVIMENTO,6
3.7	MODELAGEM DE AMEAÇAS,6
3.8	ANÁLISE DE SEGURANÇA EM CÓDIGO FONTE,6
3.9	ANÁLISE DINÂMICA DE APLICAÇÕES,6
3.10	ASSINATURA DE CÓDIGO EXECUTÁVEL,6
3.11	PROTEÇÃO DE APLICATIVOS MÓVEIS,6
3.12	RESPONSABILIDADES,7
3.12.1	GESTOR DA INFORMAÇÃO,7
3.12.2	GECMI,7
3.12.3	CESET,7
3.12.4	EQUIPES DE DESENVOLVIMENTO,7
3.12.5	ÁREA SIGNATÁRIA,8
4	PROCEDIMENTOS,8
5	ANEXOS,8

PREFÁCIO**TÍTULO****PADRÕES DE VERIFICAÇÃO DE SEGURANÇA DE APLICAÇÕES****UNIDADE RESPONSÁVEL****GECMI – GN MONIT INTEGRADO DE SEG CIBERNETICA****PÚBLICO ALVO**

Todas as unidades.

ALTERAÇÕES EM RELAÇÃO À VERSÃO ANTERIOR

Inclusões:

Item [3.11](#) e subitens – Trata sobre a proteção de aplicativos móveis com a utilização de ferramenta de RASP.

Alterações:

- O conteúdo anteriormente disposto no **Item 4** foram realocados para o **Item 3**, tendo em vista que não se tratava de procedimentos operacionais, mas sim de atribuições e responsabilidades

Item [3.1.22](#) – Todos os sistemas devem garantir a validação de itens de segurança para habilitar a execução de transações, independentemente das críticas prévias executadas em outras camadas de infraestrutura, serviços ou API anteriores.

Item [3.5.3.1](#) – Consideram-se aplicações críticas as aplicações corporativas ou de terceiros, que possuem informações corporativas confidenciais ou de natureza pessoal e que sejam acessíveis externamente.

Item [3.12.1.11](#) – Validar que as proteções da ferramenta de RASP aplicadas ao canal sob sua gestão não afetam as funcionalidades negociais.

Item [3.12.1.12](#) – Validar as mensagens de orientação apresentadas aos usuários nas situações de impedimento devido a ação de alguma proteção provida pela ferramenta de RASP.

Item [3.12.2.4](#) – Autorizar o uso da ferramenta de RASP para proteção de aplicativos móveis.

Item [3.12.3.4](#) – Realizar a gestão operacional da ferramenta de RASP.

Item [3.12.4.8](#) – Utilização da ferramenta RASP no aplicativo autorizado pela GECMI

RELAÇÃO COM OUTROS NORMATIVOS

[OR016 Tratamento da Informação](#)

[PO007 Política de Segurança e Informação](#)

[TE060 Concessão de Acesso Lógico aos Recursos Computacionais da CAIXA - Usuários Internos](#)

[TE079 Criptografia na CAIXA](#)

[TE111 Padrões Arquiteturais CAIXA](#)

[TE159 Matriz de Perfis de Acesso a Sistemas - MPAS](#)

[TE168 Identificação de Vulnerabilidades de Segurança Cibernética](#)

[TE177 DIRETRIZES PARA O DESENVOLVIMENTO DE APLICATIVOS](#)

[TE191 Usuário de Serviço - Padrões para Criação, Gerenciamento e Uso](#)

[TE202 Serviços de Diretórios de Usuários para Sistemas e Aplicativos](#)

[TE213 Gestão de Riscos de TI](#)

PRODUTOS RELACIONADOS

[Não se aplica](#)

PROCESSOS RELACIONADOS

[PR.02084 - 4.8.4.29 Proteger os serviços críticos de infraestrutura](#)

REGULAMENTAÇÃO UTILIZADA

Norma Complementar GSIPR nº 16, de 21/11/2012

DOCUMENTAÇÃO UTILIZADA

[Não se aplica.](#)

ROTEIRO PADRÃO

[Não se aplica.](#)

NORMATIVOS REVOGADOS

[Não se aplica](#)

ATENDIMENTO DE DÚVIDAS

[GECMI – GN MONIT INTEGRADO DE SEG CIBERNETICA](#)

PADRÕES DE VERIFICAÇÃO DE SEGURANÇA DE APLICAÇÕES

1 FINALIDADE

1.1 Estabelece padrões de verificação de segurança de aplicações, guiando e promovendo a aplicação das melhores práticas de segurança no ciclo de desenvolvimento de sistemas.

2 DEFINIÇÕES

2.1 Disponível em <http://dados.caixa/portal/glossario?norma=TE197>.

3 REGRAS

3.1 DIRETRIZES GERAIS

3.1.1 As diretrizes e ações abrangem as atividades de desenvolvimento de novos sistemas e de manutenção em sistemas já existentes.

3.1.1.1 A adequação dos sistemas legados às diretrizes desta norma fica condicionada a uma avaliação de custo-benefício, salvo as exceções explicitamente citadas.

3.1.2 Conforme [MN, [PO007](#)], devem ser adotados mecanismos e processos para a garantia da confidencialidade, integridade, disponibilidade e autenticidade das informações armazenadas nos sistemas de informação da CAIXA.

3.1.3 O [MN, [TE177](#)] estabelece as diretrizes e controles institucionais para o processo de desenvolvimento de sistemas, ao qual esta norma complementa com as diretrizes de segurança.

3.1.4 Conforme o princípio de Segurança desde a concepção, definido na [MN, [PO007](#)] – Política de Segurança e Informação, a segurança no desenvolvimento ou manutenção de sistemas deve ser considerada desde o início do projeto ou serviço e permeia todo o ciclo de desenvolvimento, visando mitigar riscos futuros, evitar retrabalho e reduzir custos.

3.1.5 O processo de DevSecOps preconiza a adoção de práticas e atividades de segurança em todas as etapas do ciclo de desenvolvimento de software, com foco em aplicações mais seguras, conforme descrito no [PPDS](#).

3.1.6 Todo sistema, incluindo projetos de mobilidade, seja em etapa de manutenção ou novo projeto, deve executar obrigatoriamente em seu ciclo de desenvolvimento a etapa de análise de segurança em código fonte, conforme item [3.8](#).

3.1.7 Para aqueles sistemas que não estão na esteira corporativa, as orientações de como executar a análise estática de segurança de código fonte estão disponíveis no [PPDS](#), Guia de análise estática de código fonte.

3.1.7.1 Para os sistemas da plataforma alta, a análise de segurança em código fonte é realizada pela ferramenta de qualidade de código.

3.1.8 Todo sistema, desde o início do ciclo desenvolvimento, deve considerar os requisitos de segurança para garantir uso de padrões de codificação segura e a eliminação de vulnerabilidades, conforme *checklist* disponível no [PPDS](#).

3.1.9 Nas definições de acesso dos novos sistemas e aplicativos de negócios, os limites de confiança são determinados conforme necessidade do negócio e os níveis de classificação das informações.

3.1.10 Cabe a cada envolvido no ciclo de desenvolvimento usar os recursos e informações a que tiver acesso somente para o desempenho de suas atribuições.

3.1.11 As definições de arquitetura levam em conta os padrões arquiteturais descritos no [MN, [TE111](#)], conjuntamente com as necessidades de segurança do sistema e as práticas de segurança em profundidade.

3.1.12 Os sistemas respeitam a separação dos ambientes: Internet, Extranet, Intranet e de qualquer rede pública.

3.1.13 As diretrizes de serviços de diretórios de usuários para sistemas estão contidas no [MN, [TE202](#)].

3.1.14 A manipulação de senhas é protegida de forma a não ser trafegada ou armazenada em texto plano no código fonte ou em qualquer forma de armazenamento temporário, conforme [MN, [TE079](#)].

3.1.15 Todos os sistemas devem obrigatoriamente utilizar o protocolo TLS/SSL para tráfego das informações de autenticação e sessão, conforme diretriz estabelecida no [MN, [TE079](#)].

3.1.16 O acesso dos usuários a qualquer banco de dados em produção só é realizado por meio do aplicativo ou sistema, salvo os casos previstos no [MN, [TE060](#)].

3.1.17 A conexão com o banco de dados só deve ser concedida após identificação, autenticação e autorização do usuário, serviço ou sistema.

3.1.18 O acesso para publicação e administração dos sistemas e serviços é feito exclusivamente no ambiente intranet.

3.1.19 Os sistemas e aplicativos que estejam em desuso devem ser desativados.

3.1.20 Os serviços ou funcionalidades desnecessárias ao funcionamento dos aplicativos e sistemas, após verificação de impacto, devem ser desativados ou removidos dos sistemas operacionais, servidores e/ou bancos de dados.

3.1.21 Os sistemas devem manter atualizadas as matrizes de recurso, conforme orientação publicada no PPDS.

3.1.22 Todos os sistemas devem garantir a validação de itens de segurança para habilitar a execução de transações, independentemente das críticas prévias executadas em outras camadas de infraestrutura, serviços ou API anteriores.

3.2 CLASSIFICAÇÃO DO SISTEMA

3.2.1 O sistema tem suas informações classificadas conforme o [MN, [OR016](#)].

3.2.2 A classificação geral do sistema é determinada pelo nível mais restritivo atribuído entre as informações mantidas no sistema.

3.3 TRILHA DE AUDITORIA NOS SISTEMAS

3.3.1 A auditoria nos sistemas é feita por meio de registros específicos para este fim em todos os projetos, tornando possível o rastreamento de alterações e irregularidades, que devem ser armazenados em trilha de auditoria.

3.3.2 As informações armazenadas na trilha são protegidas de forma a impedir sua alteração por qualquer pessoa não autorizada.

3.3.3 A trilha de auditoria contém, minimamente, informações que caracterizam os seguintes registros:

- o tipo de evento (inclusão, alteração, exclusão, consulta);
- o autor do evento;
- a data e hora do evento;
- o endereço lógico do equipamento de origem do tipo de evento.

3.3.4 Registros adicionais podem ser incluídos de acordo com a necessidade da área gestora e/ou nível de criticidade do sistema, respeitando o sigilo e a confidencialidade das informações conforme [MN, [OR016](#)].

3.3.5 O gestor da Informação define o prazo de retenção da trilha de auditoria.

3.4 IDENTIFICAÇÃO

3.4.1 Para os sistemas internos e externos seguir as orientações do [MN, [TE060](#)].

3.4.2 A utilização de usuários genéricos não é permitida, podendo ser utilizado usuário de serviço em alguns casos, conforme [MN, [TE191](#)].

3.5 AUTENTICAÇÃO E AUTORIZAÇÃO

3.5.1 Os sistemas ou aplicativos de negócios seguem a estrutura, gestão e políticas definidas e em uso para autenticação e autorização de usuário, conforme [MN, [TE060](#)] e [MN, [TE202](#)].

3.5.2 Não são desenvolvidos sistemas que utilizem autenticação em base proprietária.

3.5.2.1 Não são adquiridas soluções que não se integrem aos mecanismos de autenticação utilizados pela CAIXA.

3.5.3 Recomenda-se que no processo de autenticação de aplicações críticas utilize pelo menos dois fatores de autenticação de categorias diferentes.

3.5.3.1 Consideram-se aplicações críticas as aplicações corporativas ou de terceiros, que possuem informações corporativas confidenciais ou de natureza pessoal e que sejam acessíveis externamente.

3.5.4 Os fatores de autenticação são:

3.5.4.1 O QUE O USUÁRIO CONHECE: Exemplo, a senha do usuário.

3.5.4.2 O QUE O USUÁRIO POSSUI: São exemplos, os tokens físicos, smartphones, certificados digitais.

3.5.4.3 O QUE O USUÁRIO É: Nesta categoria, se encontra a biometria nas formas: digital, voz, face, comportamento.

3.5.5 Os sistemas devem proteger as funcionalidades com perfis, de forma a segregar os acessos dos usuários de acordo com a necessidade de uso da aplicação, conforme [MN, [TE159](#)].

3.6 ARQUITETURA E DESENVOLVIMENTO

3.6.1 As orientações sobre arquitetura e desenvolvimento estão disponíveis no portal <https://arquiteturati.caixa> e no PPDS, respectivamente.

3.7 MODELAGEM DE AMEAÇAS

3.7.1 A elaboração do modelo de ameaças viabiliza a identificação e entendimento das ameaças possíveis ou existentes no sistema, visando dar visibilidade das vulnerabilidades aos envolvidos e abranger medidas apropriadas de tratamento conforme os níveis de risco de cada ameaça.

3.7.2 As orientações referentes ao processo de modelagem de ameaças estão disponíveis no [PPDS](#).

3.8 ANÁLISE DE SEGURANÇA EM CÓDIGO FONTE

3.8.1 A análise de segurança em código fonte é realizada em tempo de desenvolvimento, sempre que houver nova release candidata à produção, por ferramenta especializada com base em um conjunto de regras pré-definidas para verificação de vulnerabilidades e classificação de acordo com a severidade.

3.8.1.1 A ação mencionada é realizada nos sistemas cuja tecnologia seja suportada pela ferramenta de análise de segurança de código fonte.

3.8.1.2 Para situações de sistemas que não se enquadrem no item anterior é necessário seguir o rito descrito no [MN, [TE213](#)] para gestão de riscos de TI e elaboração de ações para tratamento dos riscos identificados.

3.8.1.3 Cada apontamento de vulnerabilidade é classificado automaticamente pela ferramenta de acordo com sua criticidade, podendo ser:

- Crítica
- Alta
- Média
- Baixa

3.9 ANÁLISE DINÂMICA DE APLICAÇÕES

3.9.1 A análise dinâmica de aplicações é realizada por ferramenta especializada com base em um conjunto de regras pré-definidas para verificação de apontamentos de vulnerabilidades e classificação de acordo com a severidade.

3.9.2 Cada apontamento de vulnerabilidade é classificado automaticamente pela ferramenta de acordo com sua criticidade.

3.9.3 A análise dinâmica de aplicações ocorre para aplicações conforme autorização da GECMI.

3.10 ASSINATURA DE CÓDIGO EXECUTÁVEL

3.10.1 A assinatura de código executável deve ser feita pelas áreas signatárias, considerando quem desenvolveu o código a ser assinado.

3.10.1.1 Deve-se assinar, pelo menos, o código executável a ser instalado nos pontos finais dos canais de atendimento externos (Autoatendimento/ATM, Loterias/TFL), todo código executado em navegadores de Internet (*applets*, extensões) e os aplicativos móveis a serem publicados em lojas virtuais da Internet.

3.10.1.2 Cada área que gera o código a ser assinado deverá definir o procedimento operacional para a realização da assinatura digital, de acordo com o tipo de código a ser assinado, no entanto, a ferramenta a ser escolhida deverá ser submetida à homologação da GECMI.

3.10.2 Sempre que possível, a assinatura do código deve ser um procedimento integrado à ferramenta de repositório de código ou à ferramenta de desenvolvimento do código, de modo a evitar a cópia do código a ser assinado para outras máquinas além daquelas diretamente envolvidas com o processo de desenvolvimento em si.

3.11 PROTEÇÃO DE APLICATIVOS MÓVEIS

3.11.1 A proteção de aplicações móveis é realizada por meio de ferramenta de RASP, integrada com a esteira de desenvolvimento para encapsulamento do aplicativo antes da publicação nas lojas de aplicativos.

3.11.2 A utilização da ferramenta de RASP é realizada nos aplicativos móveis conforme autorização da GECMI.

3.11.3 Todas as proteções disponíveis na ferramenta de RASP devem ser aplicadas primeiramente em modo escuta (modo de monitoramento) e a habilitação da proteção deve ser precedida de validação pelo gestor do canal.

3.11.4 As mensagens de orientação apresentadas aos usuários nas situações de impedimento devido a ação de alguma proteção provida pela ferramenta devem ser validadas pelo gestor do canal.

3.12 RESPONSABILIDADES

3.12.1 GESTOR DA INFORMAÇÃO

3.12.1.1 Planejar, definir e documentar de forma clara e objetiva os requisitos de segurança.

3.12.1.2 Classificar corretamente as informações segundo o [MN, [OR016](#)].

3.12.1.3 Definir e manter os perfis de acesso corretamente, devendo apenas ser liberado o acesso às informações a quem realmente necessite e no nível adequado da necessidade, conforme [MN, [TE159](#)].

3.12.1.4 Definir o conjunto de informações que devem compor a trilha de auditoria de forma a abranger os campos obrigatórios especificados.

3.12.1.5 Definir o prazo de retenção da trilha de auditoria.

3.12.1.6 Solicitar a desativação de sistemas, aplicativos de negócios e/ou funcionalidades que estejam em desuso.

3.12.1.7 Validar os perfis definidos na MPAS, por meio de testes após aplicação no sistema e antes da implantação da MPAS em ambiente de Produção, como forma de evitar possíveis impactos em ambiente produtivo.

3.12.1.8 Garantir a segurança das informações acerca do negócio, projeto, sistema e demais informações vinculadas a esses, não tratando tais assuntos fora do ambiente corporativo e junto a pessoas que não fazem parte do processo.

3.12.1.9 Garantir a classificação correta da informação tratada pelo sistema, concomitantemente com os acessos mínimos, de acordo com a necessidade e nível de sensibilidade dos dados.

3.12.1.10 Participar da construção do processo de modelagem e ameaças em conjunto com a equipe de desenvolvimento.

3.12.1.11 Validar que as proteções da ferramenta de RASP aplicadas ao canal sob sua gestão não afetam as funcionalidades negociais.

3.12.1.12 Validar as mensagens de orientação apresentadas aos usuários nas situações de impedimento devido a ação de alguma proteção provida pela ferramenta de RASP.

3.12.2 GECMI

3.12.2.1 Definir requisitos e propor melhorias para os processos e ferramentas utilizadas.

3.12.2.2 Realizar a gestão do processo de análise de código.

3.12.2.3 Homologar ferramentas para assinatura de código executável.

3.12.2.4 Autorizar o uso da ferramenta de RASP para proteção de aplicativos móveis.

3.12.3 CESET

3.12.3.1 Fornecer atendimento de segundo nível para questões relacionadas à ferramenta e ao processo de desenvolvimento seguro.

3.12.3.2 Realizar análise estática de aplicações quando necessário e/ou sob demanda.

3.12.3.3 Realizar testes de intrusão nas aplicações conforme diretrizes da [MN, [TE168](#)].

3.12.3.4 Realizar a gestão operacional da ferramenta de RASP.

3.12.4 EQUIPES DE DESENVOLVIMENTO

3.12.4.1 Realizar revisão de segurança dos sistemas até o nível do código fonte.

3.12.4.2 Realizar a análise estática do código fonte utilizando a ferramenta adquirida pela CAIXA em tempo de desenvolvimento.

3.12.4.3 Executar testes de segurança nas versões candidatas antes de serem publicadas no ambiente de produção e, quando não for possível, realizar testes de segurança com a versão publicada no ambiente de produção.

3.12.4.4 Providenciar a correção de vulnerabilidades encontradas nas aplicações sob sua responsabilidade.

3.12.4.5 Atualizar a MPAS em casos de criação de novas funcionalidades ou desativação de funcionalidades existentes.

3.12.4.6 Planejar e realizar o tratamento de eventuais problemas de segurança encontrados ao longo do ciclo de desenvolvimento.

3.12.4.7 Realizar o processo de modelagem de ameaças.

3.12.4.8 Utilização da ferramenta RASP no aplicativo autorizado pela GECMI.

3.12.5 ÁREA SIGNATÁRIA

3.12.5.1 Assinar o código executável por ela produzido de acordo com as diretrizes aqui definidas.

4 PROCEDIMENTOS

4.1 Não se aplica.

5 ANEXOS

5.1 Não se aplica.